Unauthorized Use or Disclosure of Beneficiary PII/PHI

One-page case study | Medicare Advantage data privacy and access control

RESIDUAL RISK **MODERATE**

Likelihood: Medium | Impact: High

RISK ID	CATEGORY	RISK OWNER	TREATMENT	TARGET	CONTROL
RA-001	Data Privacy / Access Control	Privacy & Compliance Manager	Mitigate	February 28, 2027	RBAC / Least Privilege

RISK STATEMENT

Employee carelessness or intentional misuse could result in unauthorized access, disclosure, or misuse of beneficiary PII/PHI, causing financial or privacy harm to beneficiaries and reputational, financial, and compliance consequences for the organization.

BUSINESS CONTEXT

Employees require legitimate access to beneficiary information to support Medicare Advantage eligibility verification and identify plan options based on location, healthcare providers, and medications. Necessary access creates continuing exposure to human error and insider misuse.

EXISTING CONTROLS

- MFA for system access
- Need-to-know access
- Recurring privacy and security training
- Workstation and session security
- Restrictions on recording beneficiary data
- Call recording and compliance review
- System activity monitoring

RECOMMENDED TREATMENT

Strengthen Role-Based Access Control (RBAC)

Limit access to beneficiary PII/PHI and system functions according to defined job responsibilities, legitimate business need, least privilege, and need-to-know principles.

Business owner Privacy & Compliance Manager **Technical owner** IAM / IT Security

Cost: Moderate **Effort: Moderate** **Decision: Mitigate**

IMPLEMENTATION MILESTONES

1	**Assess current access**	IAM / IT Security	**Nov 30, 2026**
2	**Define role-permission matrix**	IAM + Compliance	**Dec 18, 2026**
3	**Configure and test RBAC**	IAM / System Admin	**Jan 22, 2027**
4	**Review and approve access**	System Owners + Compliance	**Feb 5, 2027**
5	**Deploy and monitor**	IAM / IT Security	**Feb 28, 2027**
6	**Perform access reviews**	IAM + Business Owners	**Quarterly**

PORTFOLIO TAKEAWAY **Demonstrates risk analysis, PII/PHI protection, control design, RBAC, remediation planning, ownership, evidence, and residual-risk judgment.**